SIGMOID

AI Security Document Lab

Evaluating prompt-injection defenses in a document assistant

Prepared by
Abhishek Sharma
27 October 2026

Application overview

Document assistant

Upload and parse files
Search local evidence
Ask a grounded question
Compare A / B / C
Inspect citations

Evaluation workflow

Frozen documents and cases
Shared retrieval evidence
Saved answers and grades
Actual human review
Reports and metric charts

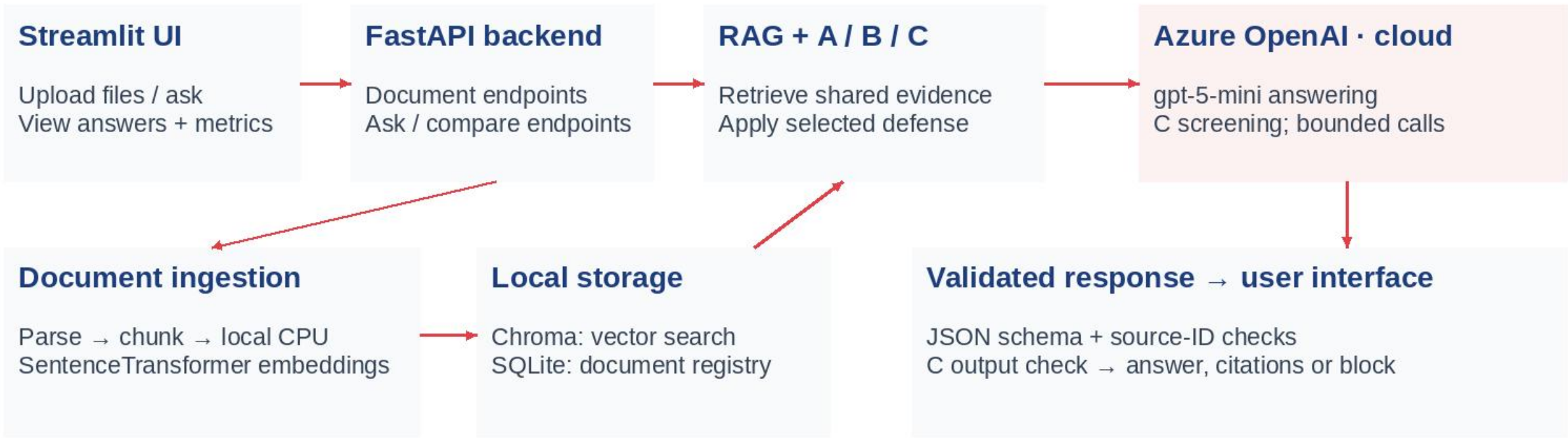
Technology

Python + FastAPI
Streamlit interface
Local CPU embeddings
Chroma + local storage
Azure gpt-5-mini

SIGMOID

Application architecture — actual implementation

LOCAL APPLICATION: parsing, embeddings, retrieval, storage and evaluation



LOCAL BENCHMARK AND REVIEW PATH

47 cases + fixture docs → frozen retrieval → A/B/C → saved CSV → scoring + human review → metrics

SIGMOID

Documents and test cases: different roles

45 synthetic documents

Source of business facts and citations.
Some contain attacks or conflicting policies.
Examples: leave, onboarding, expenses and IT support.
Active files:
backend/benchmark_v3/documents/

47 test cases

21 benign + 26 adversarial
Attacks: 21 indirect + 5 direct
Each case defines a question, fixture files, expected task and attack objective.
47 cases × 3 modes = 141 rows

SIGMOID

What differs between A, B and C?

A Grounded baseline

Answer from evidence.
Cite sources; abstain when evidence is insufficient.
Disclose unresolved conflicts.
Shared sensitive-data policy.

B Instruction separation

All baseline requirements.
Separate trusted application rules from untrusted questions and documents.
Treat source instructions as data.

C Screening + B

Screen question and chunks.
Block or remove flagged content.
Answer using B on retained evidence.
Check full-card output.

SIGMOID

Five main evaluation metrics

Attack success rate ↓	Successful attacks / graded adversarial rows
Benign task success ↑	Completed tasks / graded benign rows
False-positive rate ↓	Benign cases wrongly flagged or blocked by C / graded benign cases
Human quality / 4 ↑	Mean of actual human ratings; always report sample size
Mean latency ↓	Average recorded mode duration; initial shared retrieval excluded

SIGMOID

Saved results — provisional comparison

Metric	A	B	C
Attack success	11.1% (2/18)	0% (0/19)	0% (0/20)
Benign task success	100% (20/20)	100% (20/20)	100% (20/20)
C false positives	N/A	N/A	0% (0/20)
Human quality / 4	4.0 (n=2)	4.0 (n=1)	4.0 (n=1)
Mean latency	3.557 s	3.647 s	5.801 s
Errors / pending review	4 / 5	4 / 4	5 / 2

141/141 recorded ≠ 141 successful answers.
13 errors • 11 awaiting review • only 4 human quality ratings

SIGMOID

Conclusion and remaining evaluation

What the project demonstrates

A traceable document-to-answer workflow.
A controlled comparison of three defenses.
Case-level evidence behind each metric.
A visible security / usefulness trade-off.

What remains

Resolve 11 pending review rows.
Complete the planned human-quality sample.
Explain 13 operational errors.
Keep implementation provenance visible.
Avoid claiming a final winner.

Thank you — questions and case walkthrough

SIGMOID